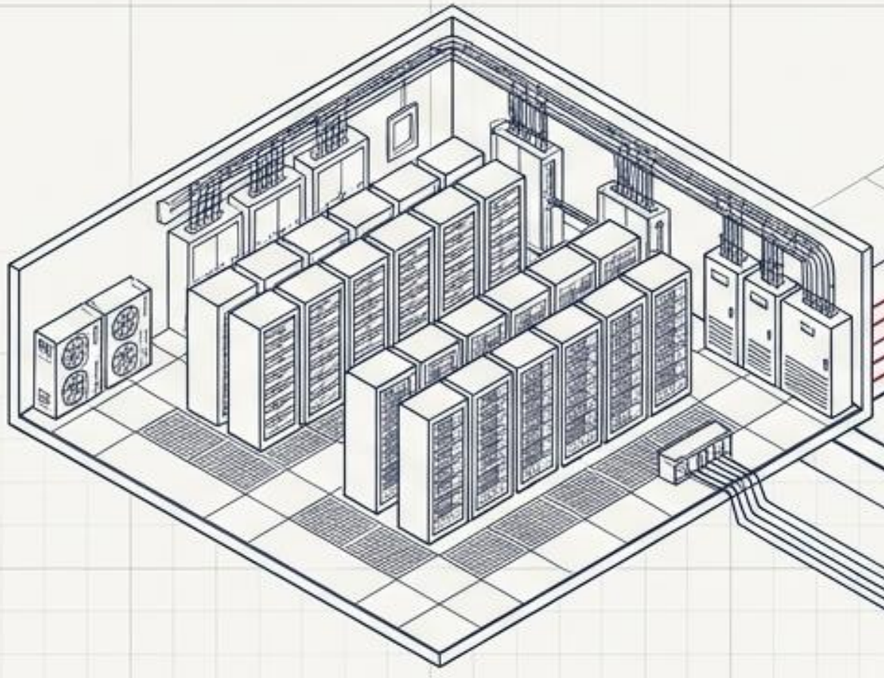
El Ecosistema de la Ciberseguridad: Más allá del Hacker

Guía definitiva de perfiles, funciones reales y rutas de estudio.



Gemini Notebook

El Mito



Trabajar en ciberseguridad no significa únicamente ser hacker ético.

La Realidad



Es un ecosistema multidisciplinar que abarca prevención, detección, respuesta, análisis técnico, arquitectura, cumplimiento y dirección estratégica.

El marco europeo ENISA ECSF define 12 perfiles profesionales estandarizados. Tu futuro puesto está en esta rueda.

Gemini Notebook

Los nombres de los puestos son ilusiones; las capacidades son la realidad

Terminal Logic Equation

90% de solapamiento en funciones diarias

[SOC Analyst L1] ≈ [Cybersecurity Analyst]

[Security Engineer (Firewalls)] ≠ [Security Engineer (DevSecOps)]

Divergencia radical en base técnica

No guíes tu carrera por el título de la vacante. Analiza siempre estas variables:

- ☑ ¿Qué problemas resuelve en su día a día?
- ☑ ¿Qué herramientas específicas utiliza?
- ☑ ¿Qué conocimientos técnicos de base necesita?
- ☑ ¿Qué nivel de responsabilidad (seniority) exige?

Gemini Notebook

Red Team
(Ofensiva)

El Perfil: Disfrutas buscando debilidades, resolviendo retos (CTFs) y entendiendo cómo atacan los adversarios.

Puestos clave:
Pentester, Auditor Web, Ethical Hacker, Security Researcher (0-days).

Blue Team
(Defensiva & Operaciones)

El Perfil: Disfrutas detectando anomalías, investigando telemetría, conteniendo ataques y protegiendo infraestructuras.

Puestos clave:
Analista SOC, Incident Responder, Threat Intelligence, Forense Digital (DFIR).

GRC
(Gobernanza, Riesgo y Cumplimiento)

El Perfil: Disfrutas analizando riesgos de negocio, diseñando políticas organizativas y comunicándote con dirección.

Puestos clave:
Analista GRC, Auditor de Ciberseguridad, CISO.

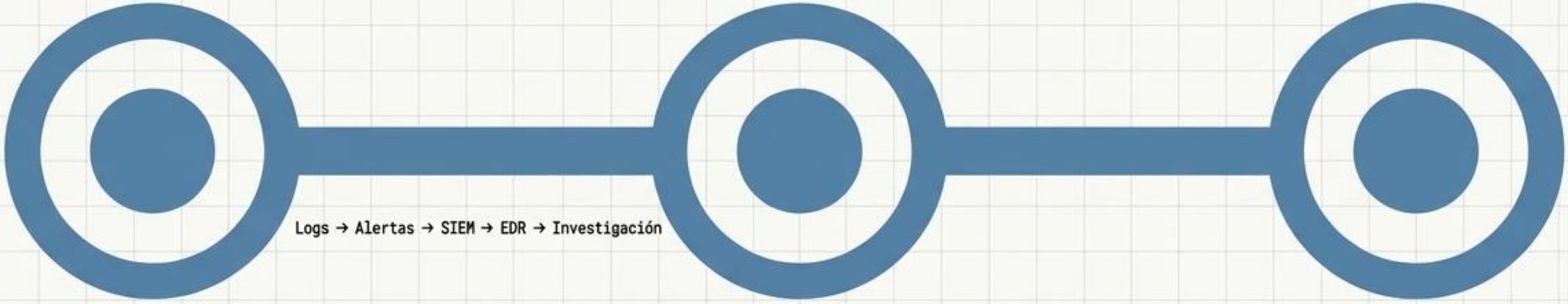
Gemini Notebook

Pipeline Defensivo: El Ciclo de Vida Operativo

Detección
(Analista SOC)

Contención
(Incident Responder)

Post-Mortem
(DFIR / Forense)



El corazón operativo. Supervisa eventos y telemetría.

Entra en acción durante intrusiones activas o ransomware. Aisla equipos, elimina persistencia y restaura el negocio según NIST SP 800-61.

Reconstruye los hechos con exactitud milimétrica. Analiza volcados de RAM, artefactos de Windows y cadena de custodia usando Autopsy o Volatility.

Gemini Notebook

Cyber Threat Intelligence (CTI)



[MITRE ATT&CK / Diamond Model]

Inteligencia Procesable

Transforma datos dispersos en alertas estratégicas. (Ej: "Un grupo APT explota esta vulnerabilidad VPN").

Ingeniero de Seguridad



Diseña, despliega y mantiene los controles técnicos de seguridad. Configura firewalls, agentes EDR y plataformas de bastionado.

Gemini Notebook

Seguridad Ofensiva: El proceso del Pentester

Evalúa aplicaciones web, APIs o infraestructuras dentro de un alcance estrictamente autorizado antes de que un atacante real las explote.

Fase 1: Reconocimiento y Enumeración

Mapeo exhaustivo de superficie de ataque. Recopilación de información pública y escaneo de puertos, servicios y activos.

Fase 2: Análisis de Vulnerabilidades (OWASP)

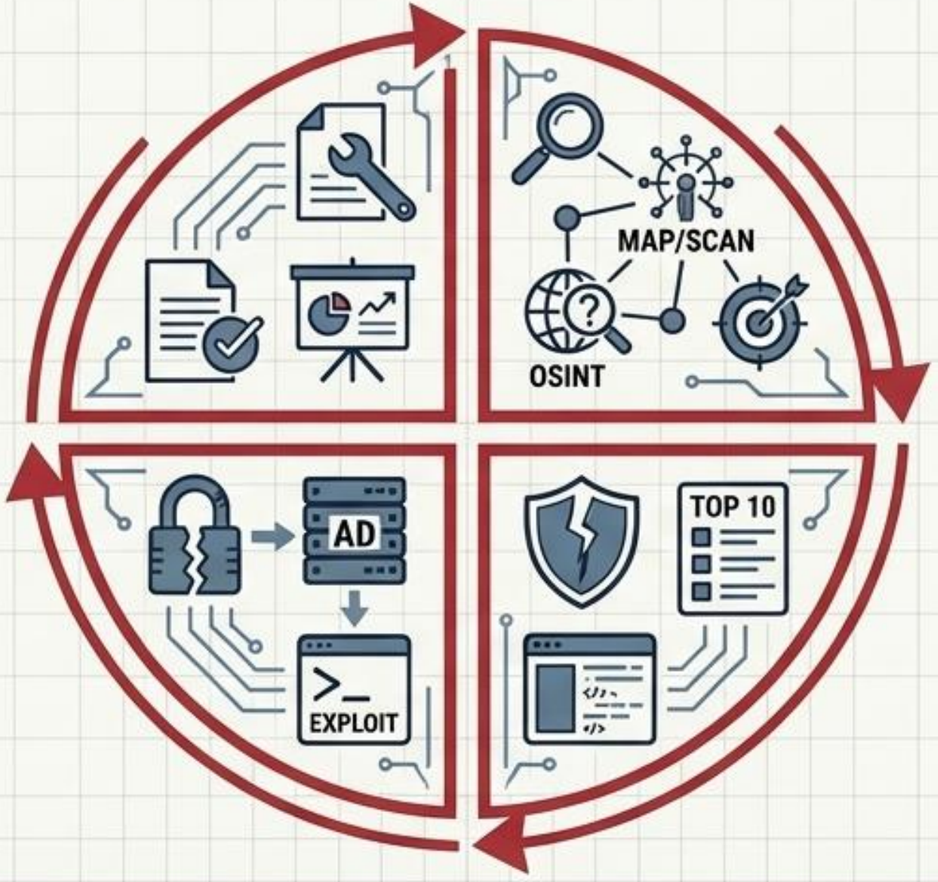
Identificación de debilidades de seguridad siguiendo metodologías estándar como OWASP Top 10. Uso de herramientas automatizadas y análisis manual.

Fase 3: Explotación y Movimiento Lateral (Active Directory)

Compromiso de sistemas mediante exploits controlados. Escalada de privilegios y movimiento lateral en la red interna, incluyendo entornos AD.

Fase 4: Propuesta de Remediación

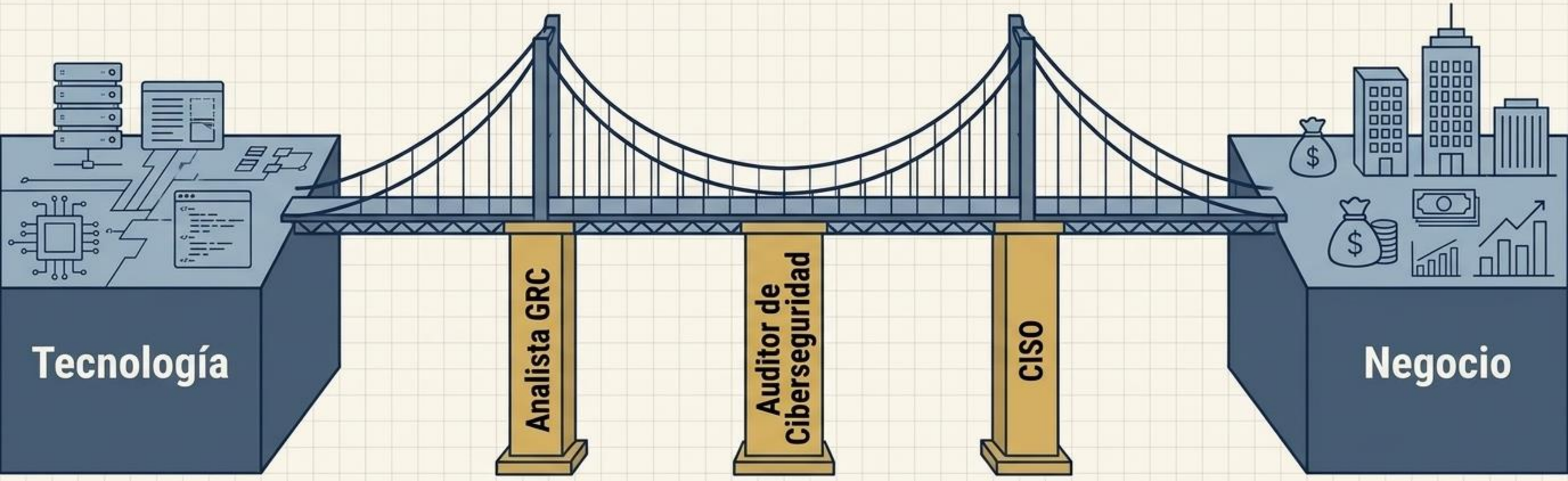
Desarrollo de recomendaciones prácticas y priorizadas para corregir las vulnerabilidades encontradas. Presentación de hallazgos técnicos y ejecutivos.



El trabajo de un hacker ético no concluye al obtener acceso; concluye cuando entrega un informe técnico riguroso que permite a la empresa corregir las brechas.

Gemini Notebook

GRC y Liderazgo: El puente entre el riesgo y el negocio



Falsamente considerado un perfil “no técnico”. Exige comprender con precisión los riesgos tecnológicos para implantar normativas (ISO 27001, NIS2, ENS, DORA) y auditar su cumplimiento real frente a lo documentado.

El CISO lidera la estrategia global. Conecta las necesidades de protección con los objetivos de negocio y traduce el riesgo tecnológico al consejo de administración.

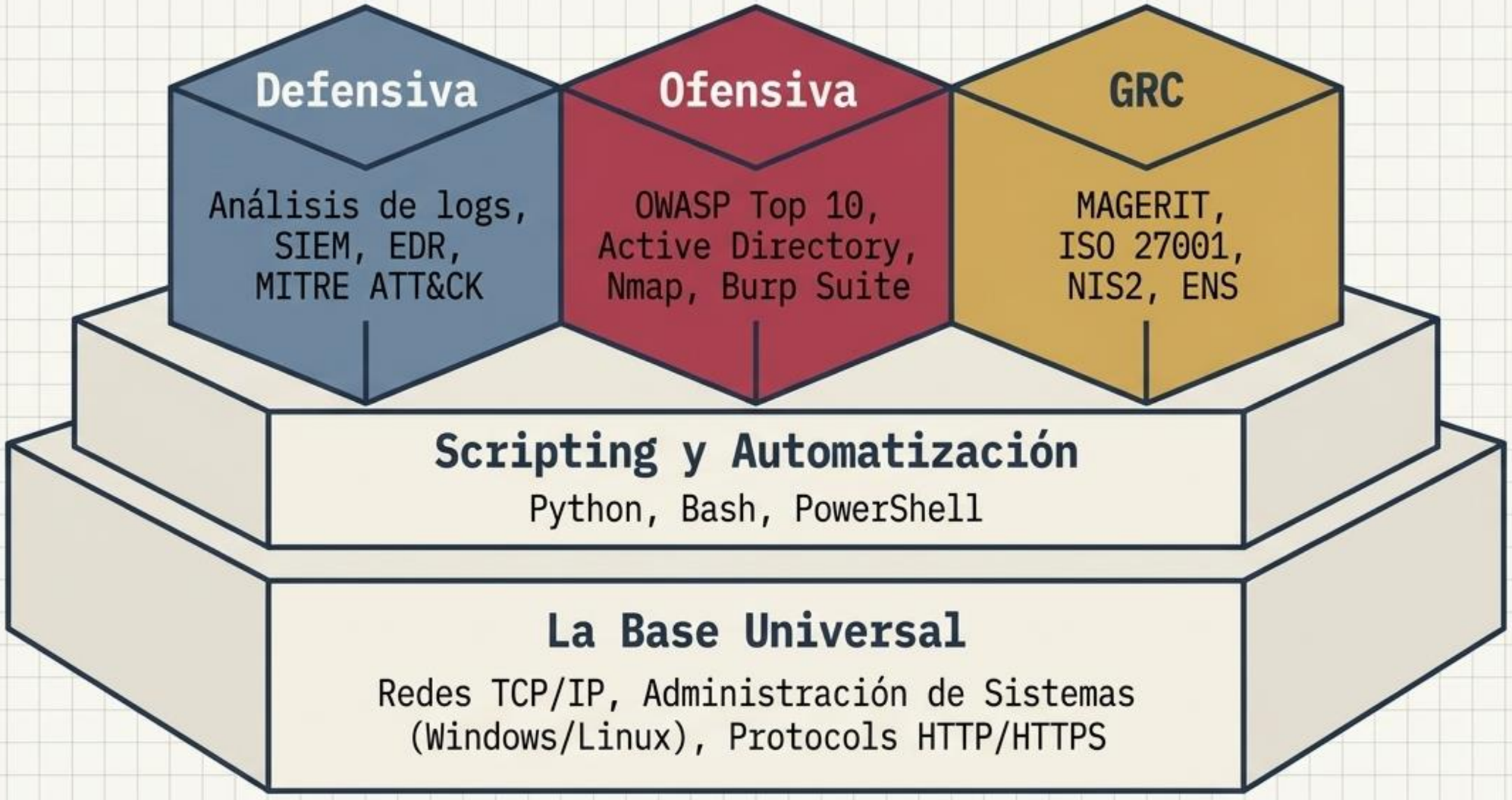
Gemini Notebook



Puestos como SOC, técnico de sistemas o GRC son los puntos de entrada más realistas. Posiciones como CISO, Arquitecto o Incident Responder exigen madurez tecnológica previa.

Gemini Notebook

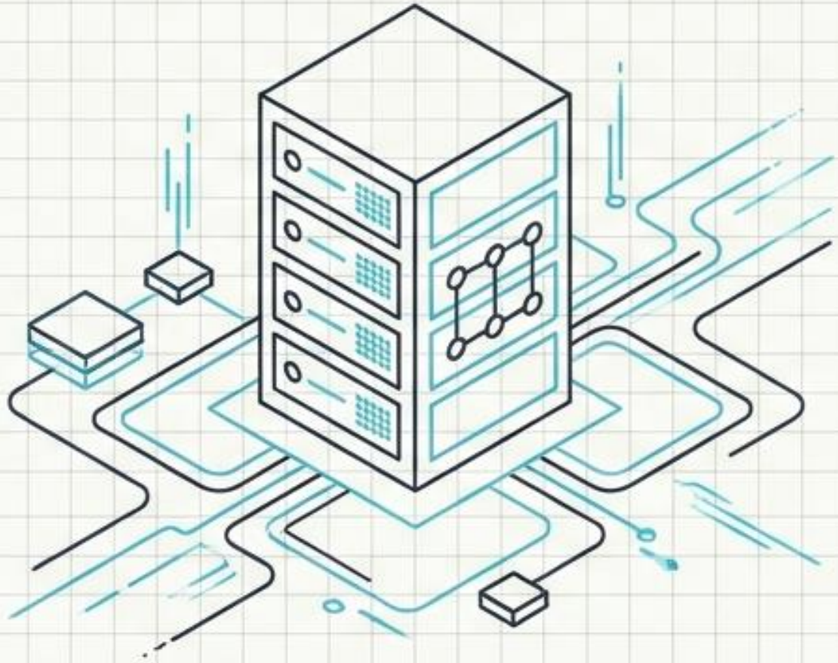
La Base Universal



Gemini Notebook

Hacking Ético

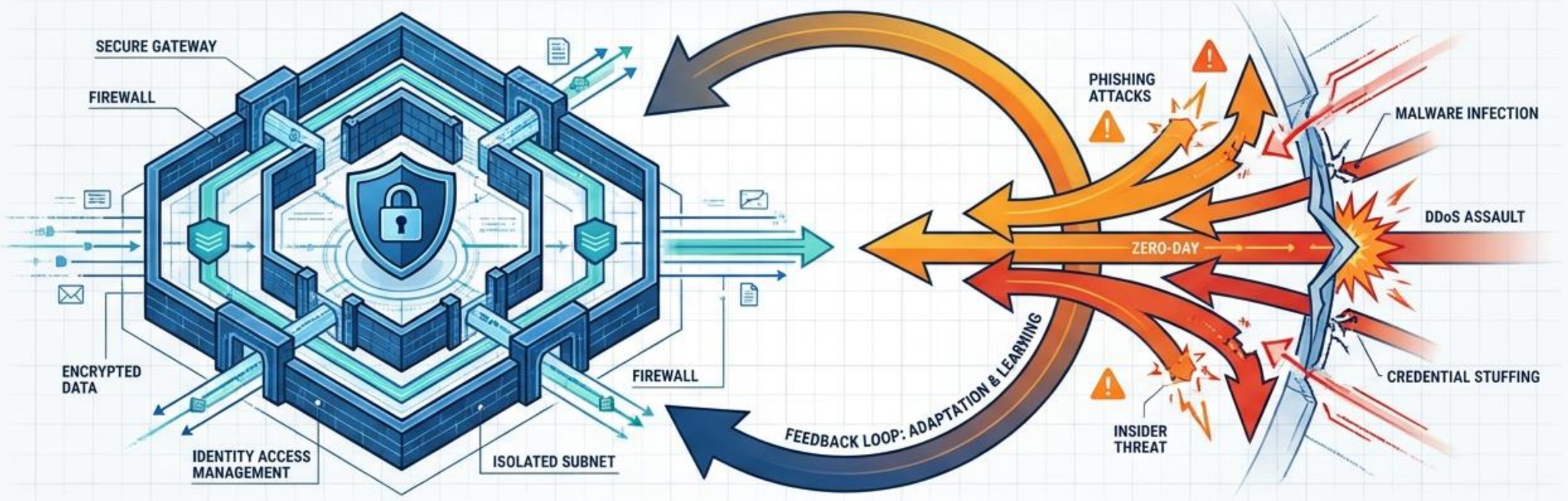
El Dossier de Seguridad: Fundamentos, Metodologías y Perfil Técnico del Pen-Tester



Gemini Notebook

El Paradigma Actual: Pensar como el Atacante

Nuestra vida diaria y empresarial depende de manera absoluta de los sistemas informáticos. Esta no es una simple casualidad técnica, es una vulnerabilidad sistémica.



Para estar verdaderamente protegido, una organización debe conocer exactamente cómo operan y qué herramientas usan los atacantes reales.

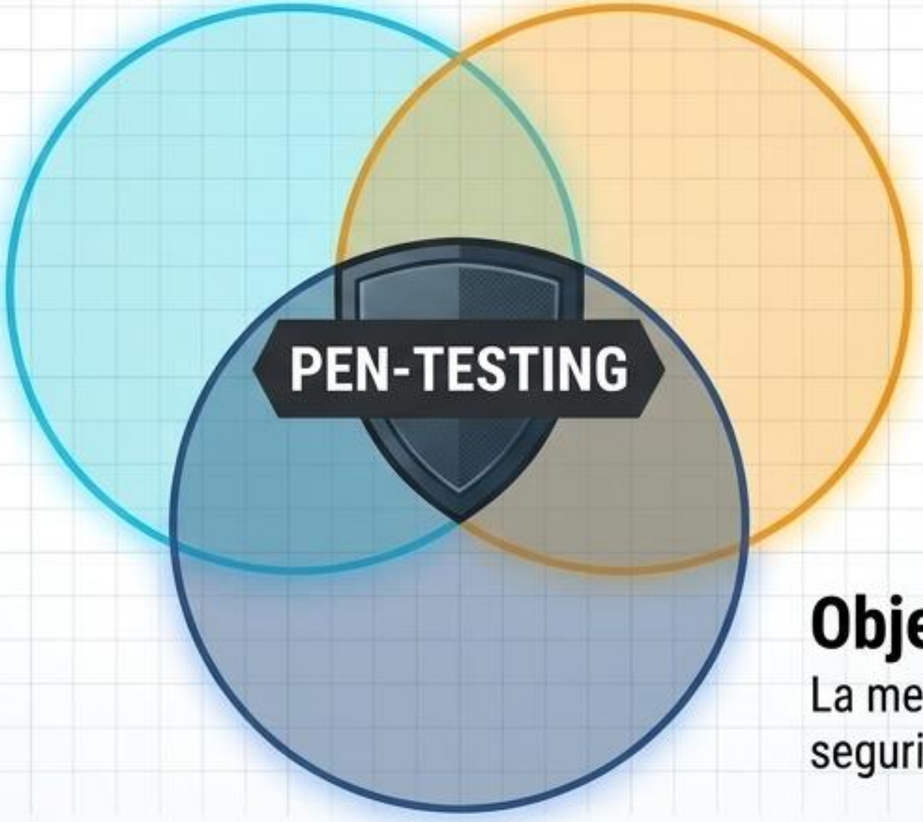
Gemini Notebook

Anatomía de una Prueba de Penetración (PEN-TEST)

"El pentesting es el acceso legal y autorizado a sistemas de información, con el objetivo de hacerlos mas seguros, a través de herramientas para la identificación y explotación de vulnera.

Acceso Legal

Ejecución bajo un marco jurídico y contractual estricto.



Acceso Autorizado

Consentimiento explícito de los propietarios del sistema.

Objetivo Constructivo

La meta exclusiva es endurecer la seguridad del sistema, no su destrucción.

Gemini Notebook

Reglas de Enfrentamiento: El Marco Contractual

Toda Prueba de Penetración requiere un escrupuloso acuerdo previo entre el Pen-Tester y la compañía cliente.



Confidencialidad Absoluta

Garantía legal de que la información interna descubierta o recibida por el consultor no será expuesta ni utilizada más allá de los fines exclusivos de la prueba.



Tiempo Total Definido

Establecimiento de una ventana de tiempo estricta para la prueba, limitando el alcance operativo y evitando interrupciones prolongadas.

Gemini Notebook

Modalidades de Ejecución: Red Team vs. Blue Team

Red Teaming
(Prueba Encubierta)

Nivel de Conocimiento
Solo un grupo selecto de altos ejecutivos está informado.

Objetivo
Evaluar no solo la infraestructura, sino la capacidad de detección y respuesta en tiempo real del equipo de seguridad interno.

Blue Teaming
(Prueba Declarada)

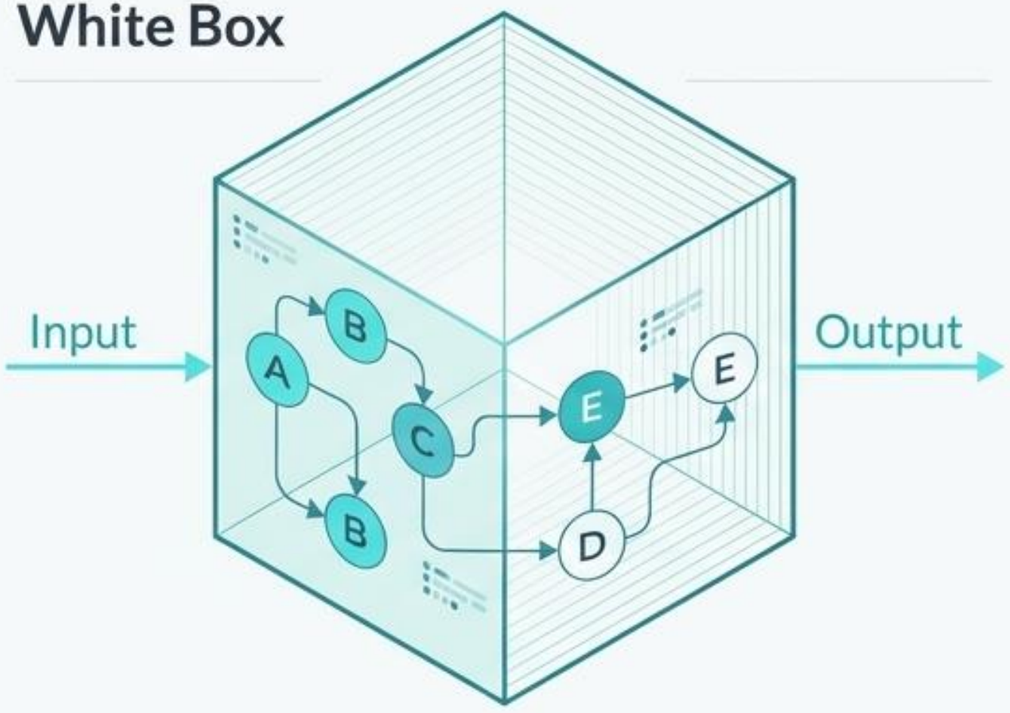
Nivel de Conocimiento
El personal de informática y seguridad conoce el desarrollo del PEN-TEST.

Objetivo
Trabajar en conjunto para identificar vulnerabilidades sistémicas de manera abierta y colaborativa.

Gemini Notebook

Metodologías de Análisis Técnico

White Box



Caja Blanca: El evaluador tiene conocimiento total de la estructura interna y el código fuente del sistema.

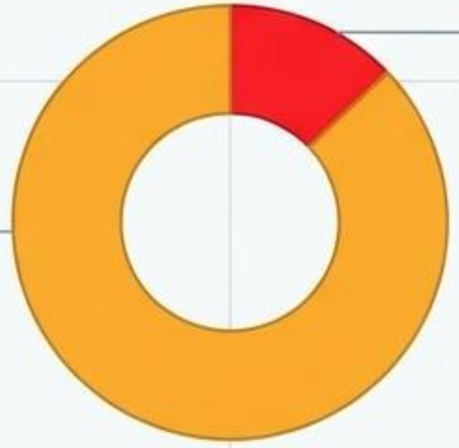
Black Box



Caja Negra: El evaluador opera a ciegas, atacando el sistema basándose únicamente en las respuestas a sus estímulos.

Gemini Notebook

El Paisaje de Amenazas: Estado de la Seguridad del Software



13% presenta gravedad crítica

>85% de las aplicaciones tienen vulnerabilidades

Proporción de componentes vulnerables



Inyección SQL: Persiste en 1 de cada 3 aplicaciones.

Cross-Site Scripting (XSS): Se encuentra en casi el 50% de las aplicaciones.

Gemini Notebook

El Lenguaje del Diagnóstico: CWE vs. CVE

	CWE (Common Weakness Enumeration)	CVE (Common Vulnerabilities and Exposures)
Qué es	Catálogo de debilidades comunes y errores de categoría.	Registro de vulnerabilidades reales, concretas y descubiertas.
Enfoque	General, conceptual y preventivo.	Concreto, aplicado a un software específico (ID = Año + Número).
Ejemplos	**CWE-89**: Inyección SQL **CWE-79**: Cross-Site Scripting (XSS) **CWE-787**: Escritura fuera de límites	**CVE-2021-44228**: Log4Shell en Apache **CVE-2017-0144**: Exploit EternalBlue (WannaCry)

Gemini Notebook

El Perfil Técnico del Pen-Tester



Redes Informáticas

Comprensión profunda de tráfico, enrutamiento y arquitectura.



Programación

Capacidad de leer, escribir y manipular código fuente.



Bases de Datos

Dominio de la extracción y manipulación de datos estructurados.



Entornos Web

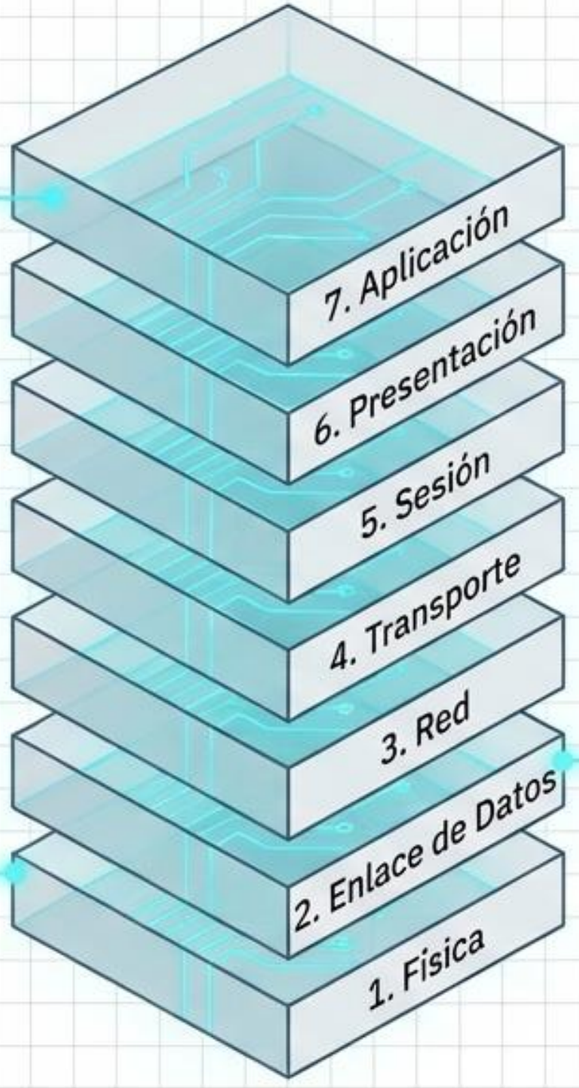
Conocimiento profundo del funcionamiento de navegadores, protocolos HTTP y aplicaciones web.

Gemini Notebook

Vectorización de Ataques: El Modelo OSI

Corporación Universitaria Autónoma del Cauca

Ataques directos a Servidores y Aplicaciones Web



Envenenamiento ARP (ARP Poisoning)

Ataque de Intercepción (Man in the Middle)

Gemini Notebook

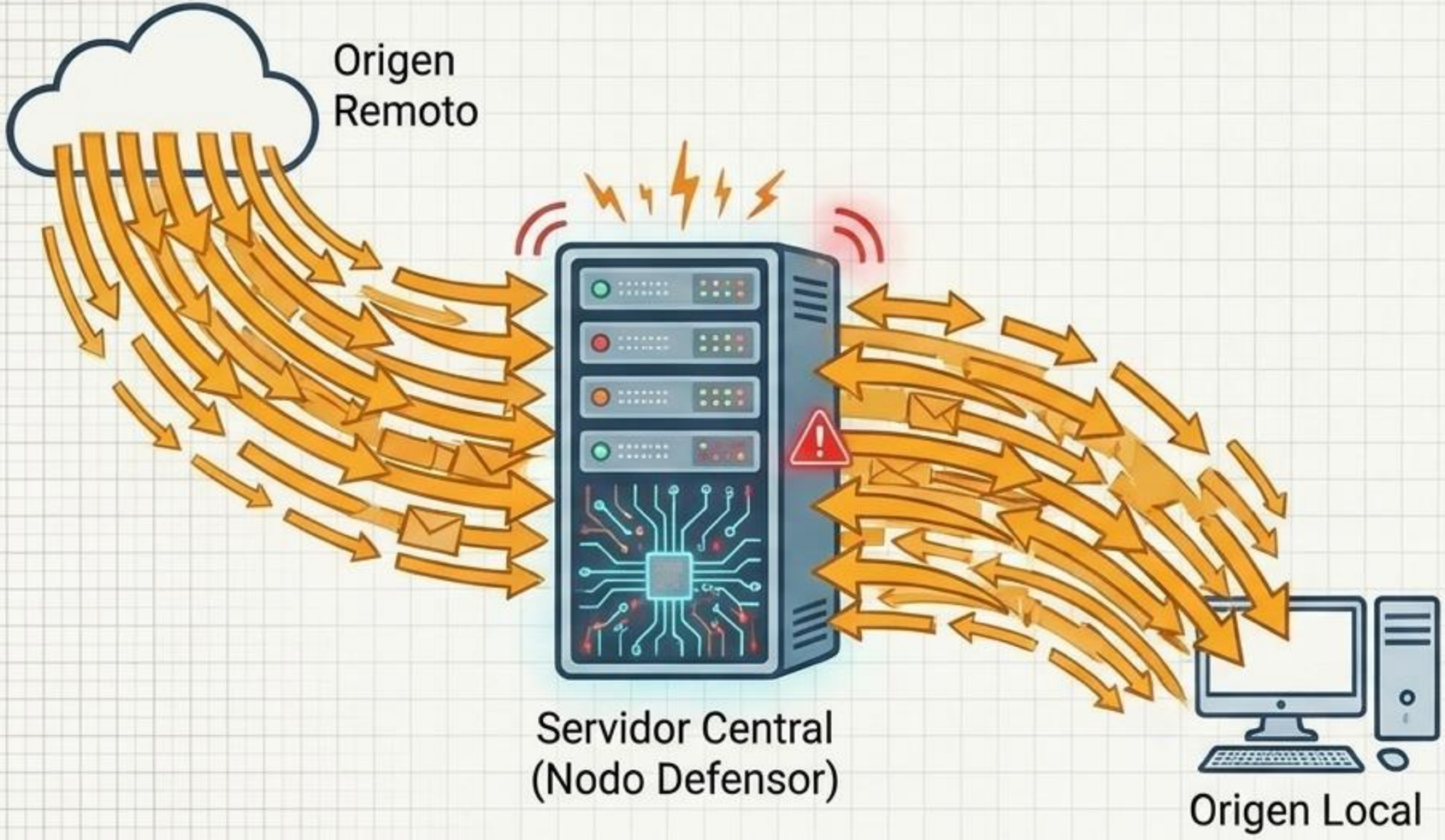
Vulnerando la Aplicación: Inyección de Código



Explotación de CWE-89 (Inyección SQL): Los conocimientos de Bases de Datos y Programación permiten a un atacante introducir inputs no sanitizados, saltando la autenticación normal para extraer o manipular información confidencial.

Gemini Notebook

Evaluando la Resistencia: Pruebas de Denegación de Servicio (DoS)

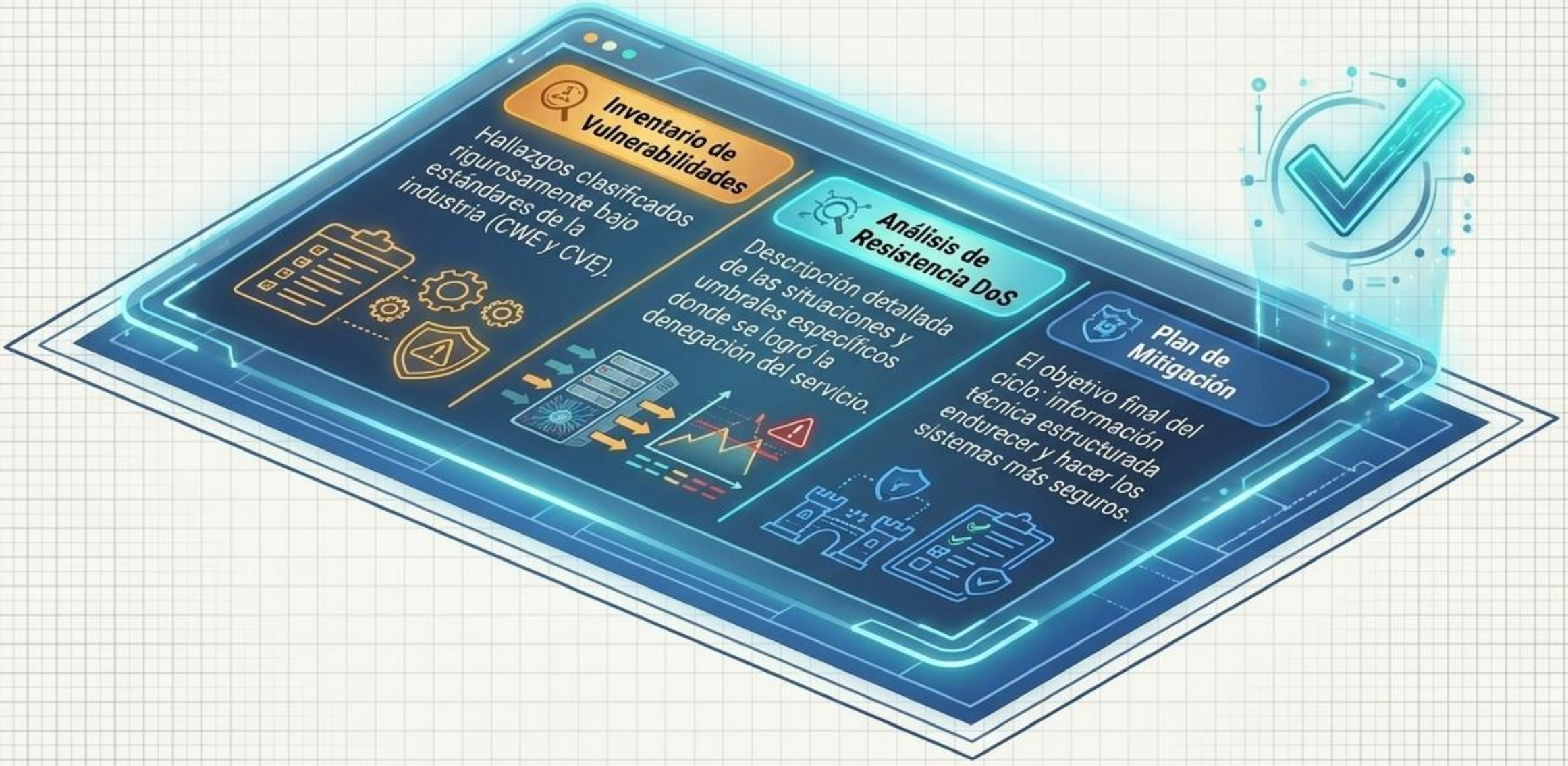


Las pruebas DoS reflejan el grado de solidez y resistencia de un servicio frente a agresores locales o remotos.

Objetivo Operacional: El objetivo no es robar datos, sino deshabilitar el sistema por completo para comprobar su punto de quiebre.

Gemini Notebook

El Entregable: Inteligencia Accionable



Gemini Notebook

El Ecosistema del Hacking Ético



El Hacking Ético es la transformación sistemática del conocimiento ofensivo en blindaje defensivo.

Gemini Notebook

Guía Fundamental del Hacking Ético y Pentesting

El Hacking Ético evalúa la seguridad de los sistemas informáticos mediante accesos autorizados para identificar y corregir fallos antes de que sean explotados. Comprender sus modalidades operativas y los estándares de clasificación de vulnerabilidades es clave para fortalecer la infraestructura tecnológica.

Modalidades y Marco del Pentesting



Acceso Legal y Autorizado

Evaluación intensiva y acordada con el cliente para identificar y explotar vulnerabilidades de forma controlada.

Modalidades Red y Blue Team



Red Team
Opera de forma encubierta.

Blue Team
Se realiza con conocimiento del equipo de TI.



Marco Legal y Confidencialidad

Requiere acuerdos formales sobre el tiempo de ejecución y la protección estricta de la información recolectada.

Clasificación de Vulnerabilidades



CWE: Debilidades de Software

Catálogo conceptual de categorías de errores usado en educación y diseño seguro de código.



CVE: Vulnerabilidades Concretas

Registro con ID único para fallos reales y específicos Identificados en sistemas o productos.

Comparativa CWE vs. CVE

Criterio	CWE	CVE
Concepto	Catálogo de debilidades de software	Base de datos de vulnerabilidades reales
Nivel	General y conceptual	Concreto y aplicado a productos
Aplicación	Prevención y diseño seguro	Gestión de parches e incidentes

Gemini Notebook

El Valor del Hacking Ético



Diagnóstico

Conocimiento exacto del grado de vulnerabilidad de los sistemas de información. Imprescindible para aplicar medidas correctoras.



Mitigación de Riesgos

Reducción de riesgos que representan pérdidas de capital, ya sea por facturación fallida o reposición de daños.



ROI y Ahorro

Ahorro de tiempo y dinero al afrontar y corregir situaciones nefastas de forma proactiva, evitando resolverlas con prisas y a cualquier precio.

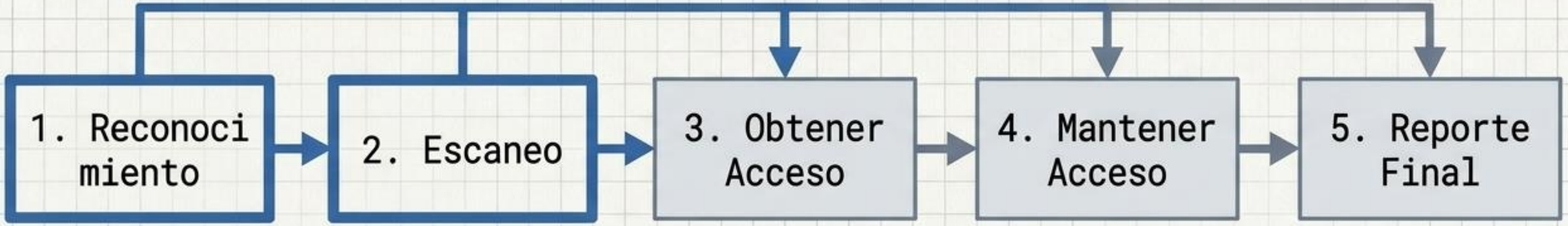
Gemini Notebook

Matriz de Frameworks y Metodologías

OSSTMM	ISSAF	OTP (OWASP)
Orden y Calidad	Prácticas Detalladas	Aplicaciones Web y SDLC
Estándar de referencia imprescindible para llevar a cabo un testeo de seguridad de forma ordenada y con calidad profesional.	Framework exhaustivo que detalla las prácticas y cada una de las tareas específicas a realizar al conducir un testeo de seguridad.	Metodología en dos partes: 1) Principios y explicación del framework. 2) Planificación de técnicas para testear cada paso del ciclo de vida del desarrollo de software (SDLC).

Gemini Notebook

Las 5 Fases del Pentest



(Obtención de información activa/pasiva).

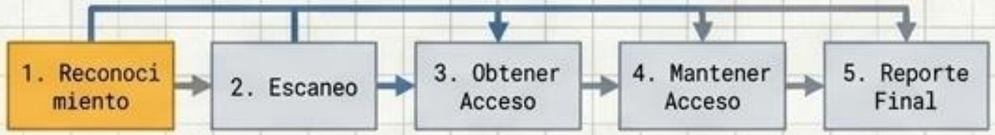
(Búsqueda de vulnerabilidades explotables).

(Explotación de la vulnerabilidad).

(Instalación de backdoors/ persistencia).

(Consolidación de hallazgos).

Gemini Notebook



Fase 1: Reconocimiento

La fase donde se obtiene información acerca del objetivo usando medios activos o pasivos.

Herramientas de Red



- NMAP
- Hping

Herramientas OSINT/Datos

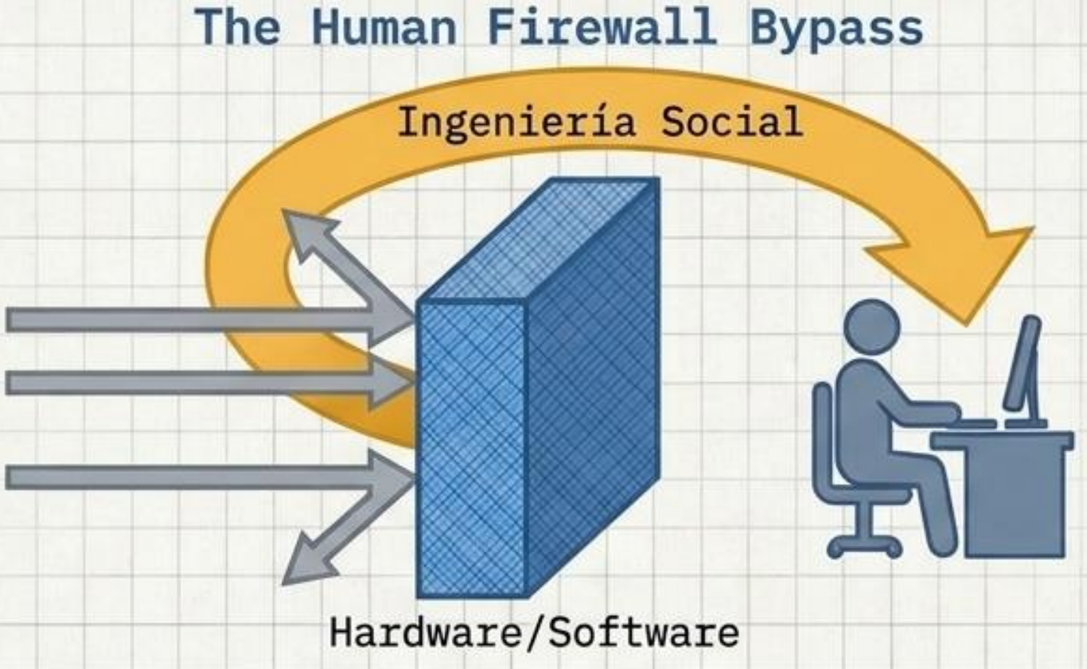


- Maltego
- Google Dorks

Gemini Notebook

El Eslabón Más Débil: Ingeniería Social

Técnica que consiste en manipular psicológicamente a las personas para que compartan información sensible o realicen acciones inseguras.



Como es un tema más humano que tecnológico, ni el hardware ni el software que implementan las compañías pueden prevenir los ataques.

Gemini Notebook

Técnicas OSINT: Google Hacking

Técnica de obtención de información (Information

Técnica de obtención de información (Information Gathering) que uso de las altas capacidades del motor de búsqueda Google.



```
site:gov.co ext:pdf "informe confidencial" AND -publico
```

Las búsquedas se refinan para encontrar datos específicos mediante el uso de:

- Operadores Lógicos: `AND` - `OR` - `NOT`
- Operadores Avanzados: (Detallados en la siguiente matriz).

Gemini Notebook

Cheat Sheet: Operadores Avanzados

`""`	Resultados literales (ej. “`hola mundo`”)
`+`	Palabras obligatorias (ej. `fresas +rojas`)
`-`	Excluye palabras (ej. `bancos -muebles`)
`~`	Sinónimos (ej. `~sueldo -> salario, remuneración`)
`inurl:`	Incluye la palabra en la dirección (ej. `inurl:gobierno`)
`site:`	Limita la búsqueda a un dominio/servidor (ej. `site:gov.co`)
`ext:`	Una extensión en especial (ej. `ext:pdf`)
`allintext:`	Texto en el cuerpo de la página (ej. `allintext:sueldo`)

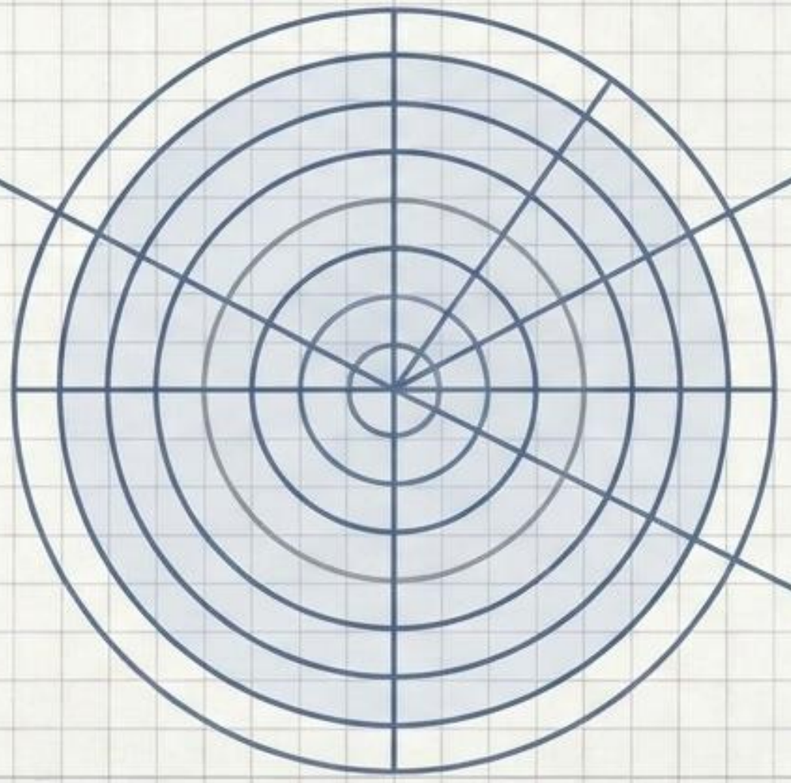
Gemini Notebook

1 → 2 → 3 → 4 → 5

Fase 2: Escaneo y Detección

En esta fase se comienza a probar el sistema o red objetivo en busca de vulnerabilidades explotables.

- Detectar puertos Abiertos.
- Detectar puertos Protegidos por cortafuegos.
- Detectar puertos Cerrados.



Gemini Notebook

Matriz de Diagnóstico: Escaneo de Puertos

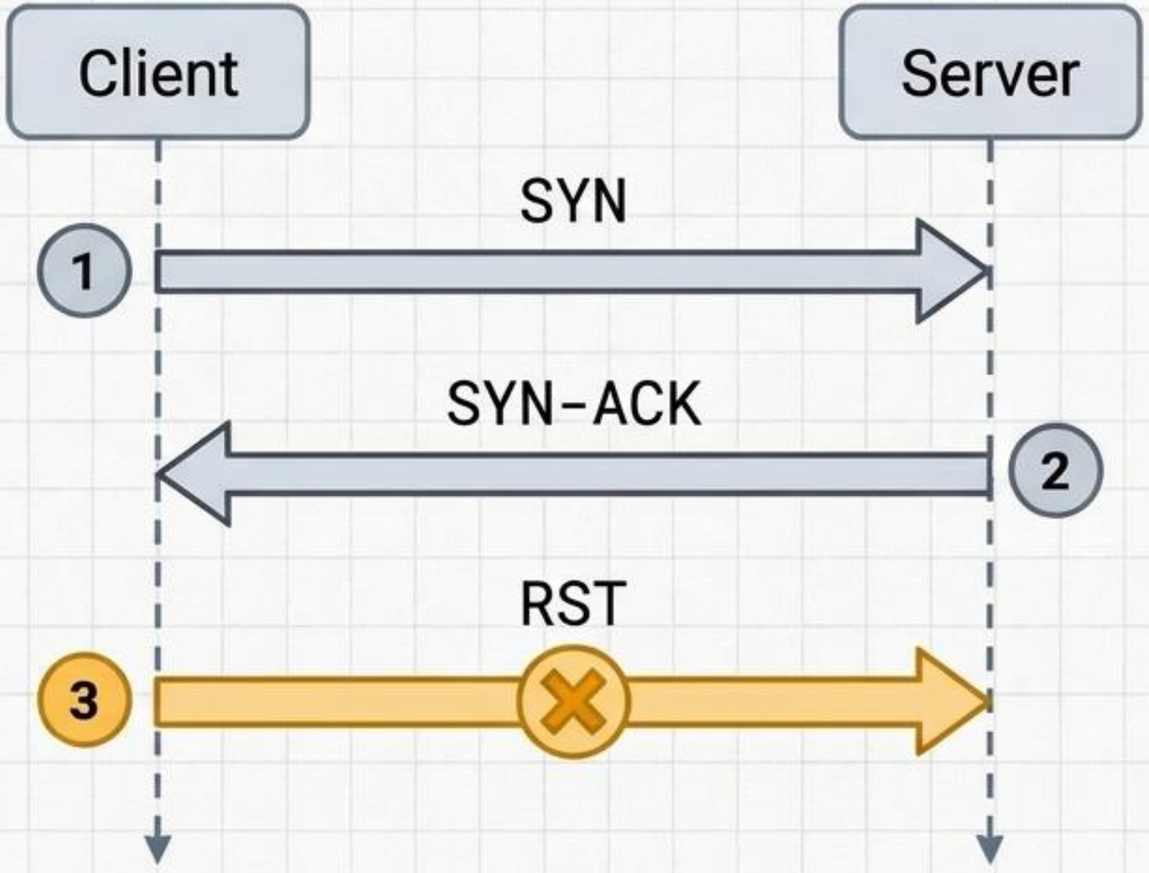
	`-sS (TCP SYN)`	`-sT (TCP CONNECT)`	`-sU (UDP SCAN)`
Perfil	Sigiloso / Half-Open	Completo / Sin Privilegios	El Punto Ciego / Servicios Específicos
Velocidad/Eficiencia	Muy Rápida (Por defecto)	Menos Eficiente	Lenta y Compleja
Combinabilidad	Base principal	Alternativa a -sS	Combinable con -sS

Gemini Notebook

TCP SYN Scan (-sS): El Enfoque Sigiloso

```
nmap -sS [objetivo]
```

- Conocido como SYN Stealth o Half-Open Scan.
- Es la técnica más popular y la utilizada por defecto.
- Ventaja clave: Permite escanear miles de puertos por segundo de forma relativamente **sigilosa**, ya que **no finaliza las conexiones que abre**.

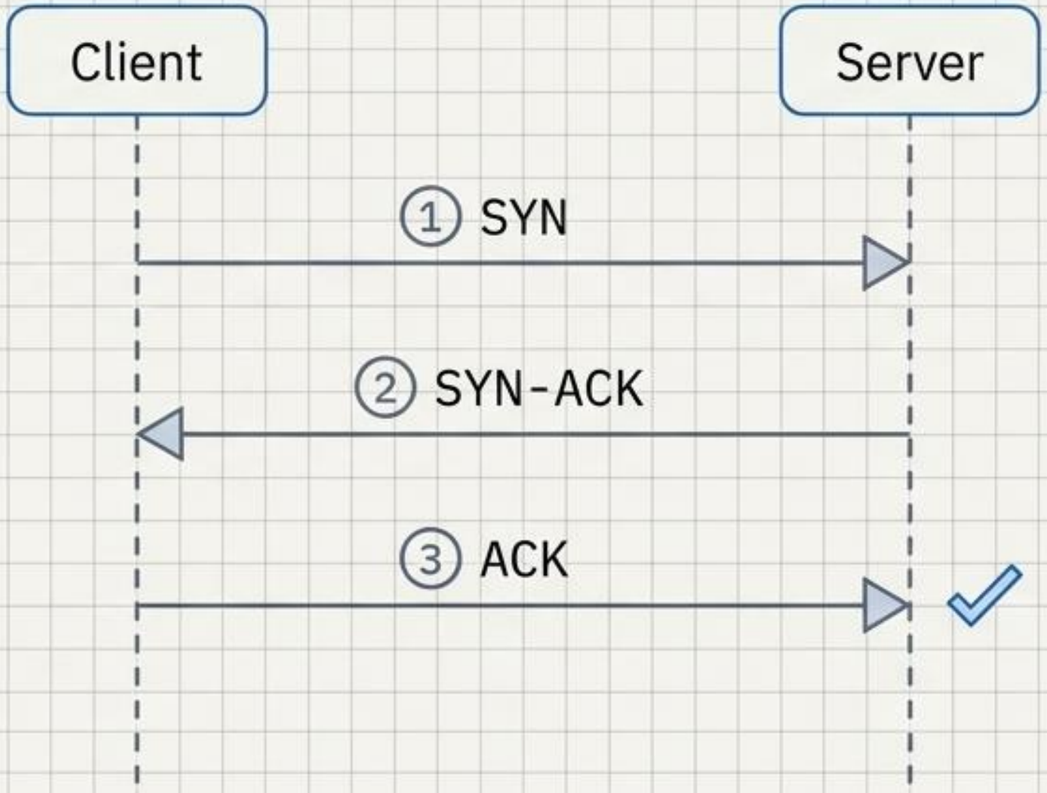


Gemini Notebook

TCP CONNECT (-sT): La Alternativa sin Privilegios

```
nmap -sT [objetivo]
```

- Se utiliza por defecto cuando **no es posible usar SYN Scan (-sS)** debido a que el usuario no tiene suficientes privilegios en el sistema.
- Desventaja operativa: Es menos eficiente. Nmap no toma el control de los paquetes enviados como lo hace en la mayoría de las otras técnicas, requiriendo completar la conexión real.



Gemini Notebook

UDP SCAN (-sU): Explorando el Punto Ciego

```
nmap -sU [objetivo]
```

1

No todos los servicios populares corren sobre TCP. Es vital no ignorar UDP.

2

Objetivos Críticos:

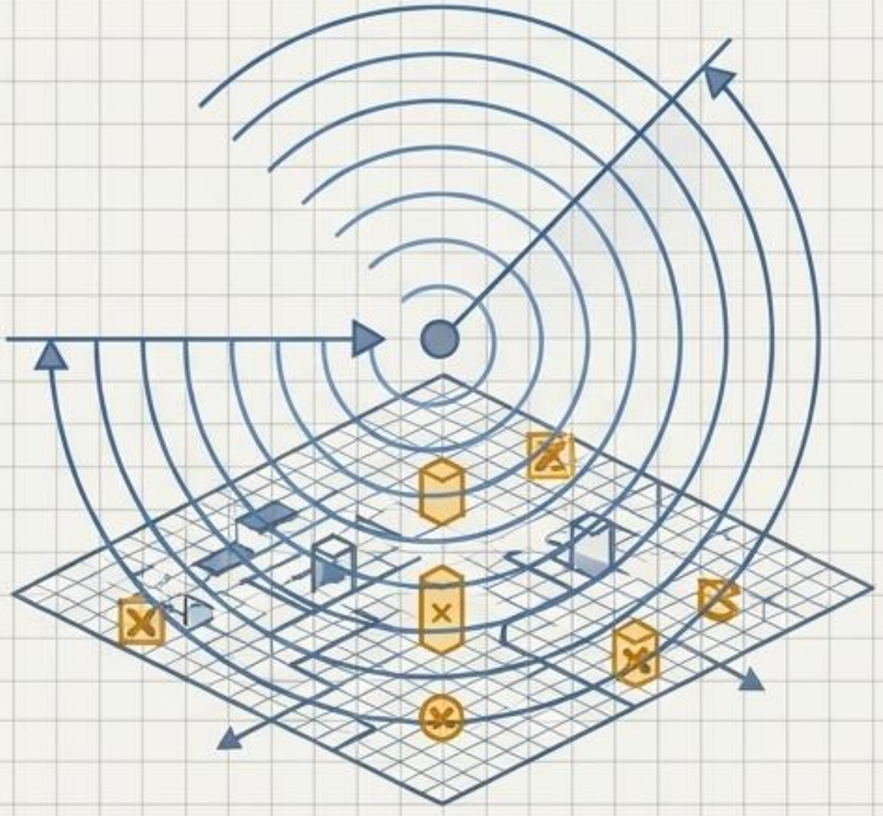
- DNS (Puerto 53)
- SNMP (Puertos 161, 162)
- DHCP (Puertos 67, 68)

3

El Reto: A menudo ignorados en auditorías porque el escaneo UDP es más complejo y lento.

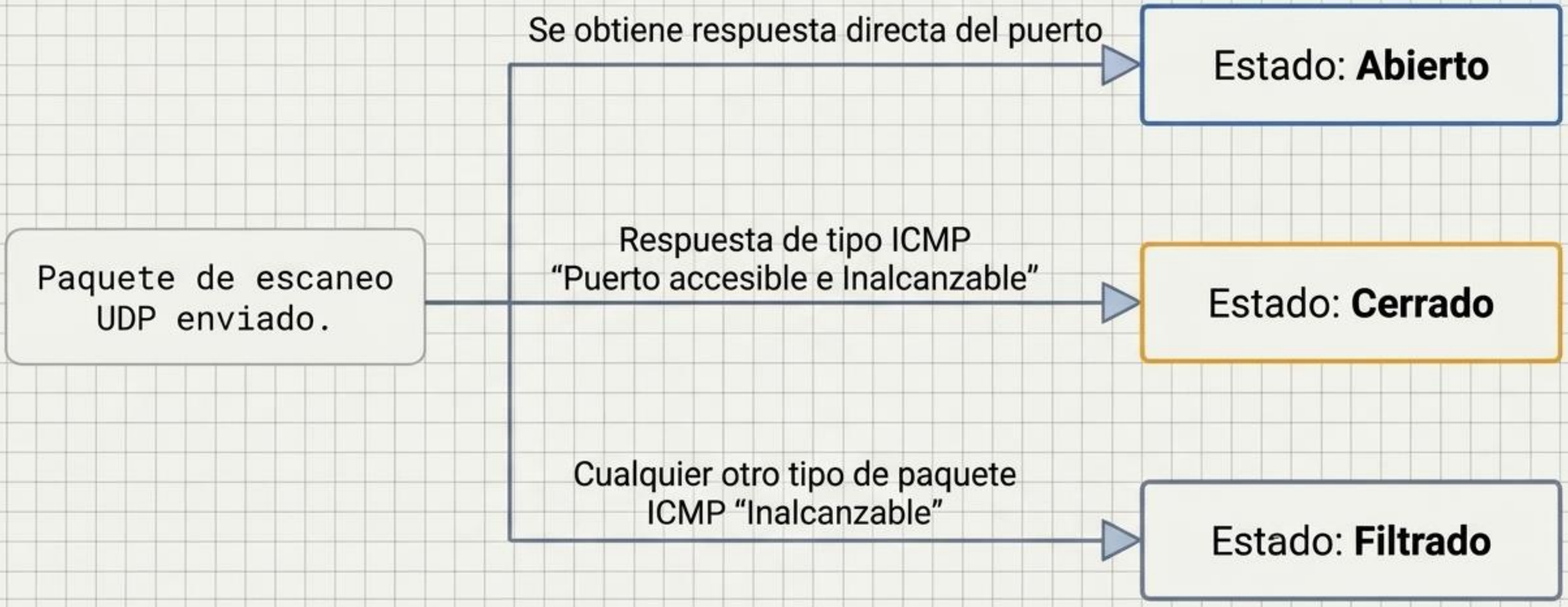
4 → **Táctica:**

Puede combinarse simultáneamente con técnicas TCP (ej. SYN scan -sS).



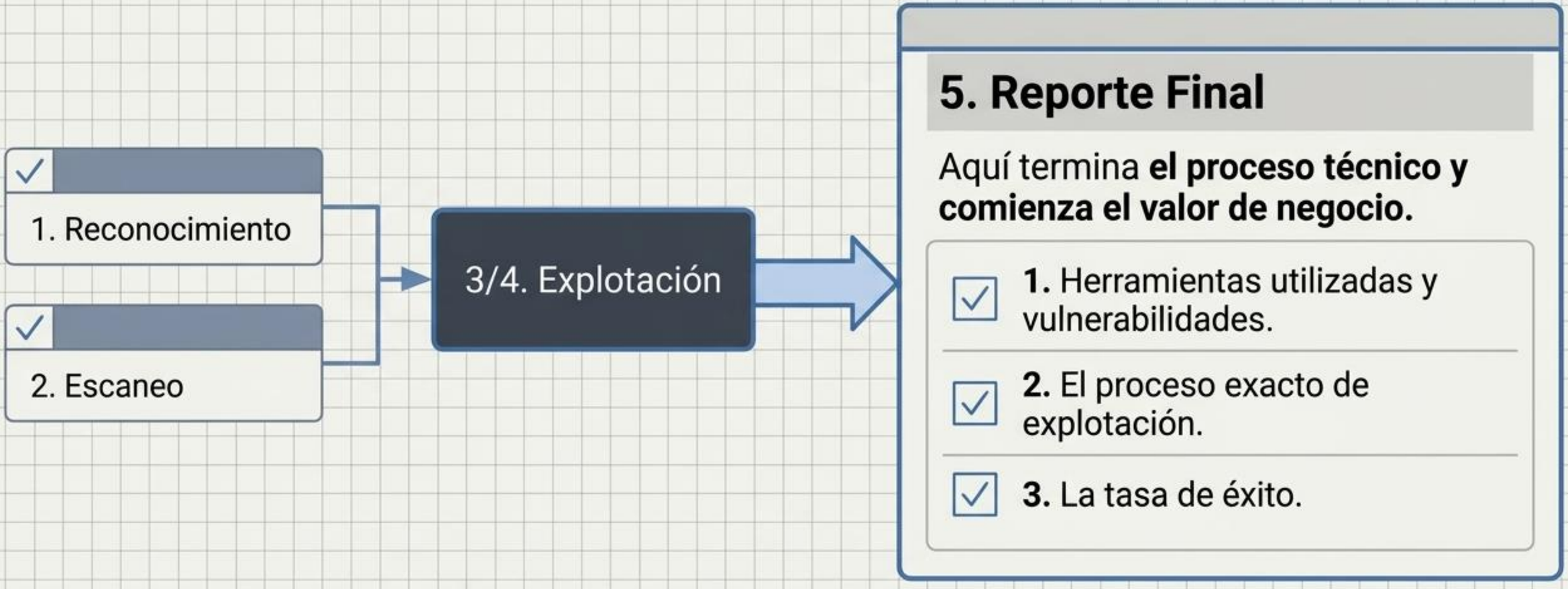
Gemini Notebook

Lógica de Estados UDP



Gemini Notebook

Síntesis: De la Explotación al Reporte



Este entregable transforma los datos técnicos crudos en la mitigación de riesgos y el ROI prometidos al inicio de la operación.

Gemini Notebook

Guía Esencial de Hacking Ético y Test de Intrusión

El hacking ético proporciona una estructura metódica para identificar y corregir vulnerabilidades en los sistemas de información antes de que ocurran ataques maliciosos, reduciendo riesgos operativos y optimizando costes de seguridad.

Fases Metodológicas del Pentest



1. Reconocimiento Inicial

Obtención activa o pasiva de información detaliada del objetivo.

2. Escaneo de Vulnerabilidades

Análisis técnico de la red y sistemas en busca de fallos.

3. Obtención de Acceso

Explotación efectiva de vuinerabilidades detectadas para ingresar al sistema.

4. Mantenimiento del Acceso

Instalación de herramientas como backdoors para asegurar accesos futuros.

5. Reporte Final

Documentación consolidada de hallazgos, tasas de éxito y remediaciones.

Marcos de Trabajo y Técnicas



Marcos Estándar de Prueba

Metodologías reconocidas como OSSTMM, ISSAF y OWASP OTP para garantizar auditorías de calidad.



Ingeniería Social y Reconocimiento

Técnicas de manipulación humana y Google Hacking con operadores avanzados para extraer datos críticos.

Escaneo de Puertos Nmap

Comparación de las técnicas de escaneo de puertos más utilizadas con Nmap

	TCP SYN Scan (`-sS`)	TCP Connect Scan (`-sT`)	UDP Scan (`-sU`)
Características Técnicas	Sigiloso (Half-Open); no completa la conexión TCP.	Completa la conexión usando la pila de red del S.O.	Evalúa servicios no orientados a conexión (DNS, SNMP).
Escenario de Uso	Opción rápida y preferida por defecto.	Uso cuando no existen privilegios suficientes.	Análisis complejo de protocolos UDP específicos.

Gemini Notebook

Academia Hacker

IT Academy



Hacking Ético

Video Series

https://www.KarinaAstudillo.com

Academia Hacker

IT Academy



Hacking Ético

Video Series

https://www.KarinaAstudillo.com

TAREA

1. Haciendo uso de los operadores mas utilizados en Google, realizar un reconocimiento de la universidad autónoma del Cauca y hacer el mismo ejercicio con otra empresa.

2. Descargar la herramienta Zenmap (versión para Windows) e instalar https://nmap.org/download.html

3. Realizar un escaneo de puertos a las plataformas de una empresa.

4. Realizar un informe completo donde se evidencie puertos abiertos y sus servicios, puertos filtrados, rango de direcciones IP, servidores, sistema operativo, motor de base de datos.